TECHNICAL DETAIL

Title	Information Disclosure via Debug Mode (Laravel Ignition Page)
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-21
Affected Asset	https://bertani.my.id/admin/posts/store
Severity	**Low**
CVSS Score	2.7 CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:N/A:N
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

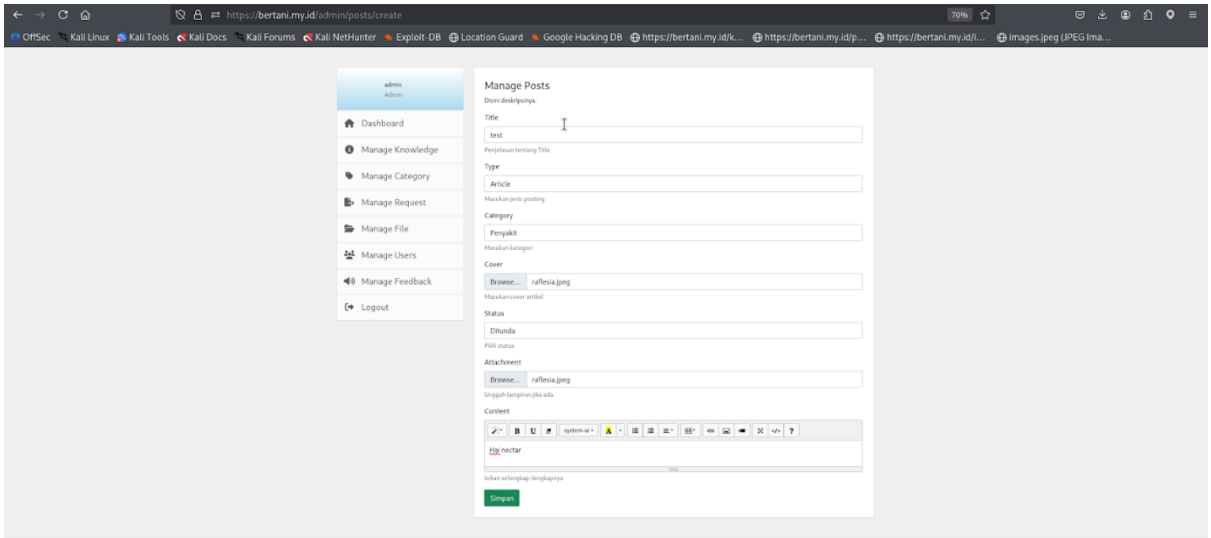
Ditemukan kesalahan konfigurasi minor (*Minor Misconfiguration*) pada server produksi di mana Mode Debug (APP_DEBUG=true) tidak dinonaktifkan.

Saat terjadi kesalahan sistem (seperti *Unhandled SQL Exception* pada fitur pembuatan postingan), aplikasi menampilkan halaman *debugging* (Laravel Ignition) yang berisi informasi teknis server, alih-alih menampilkan halaman error generik.

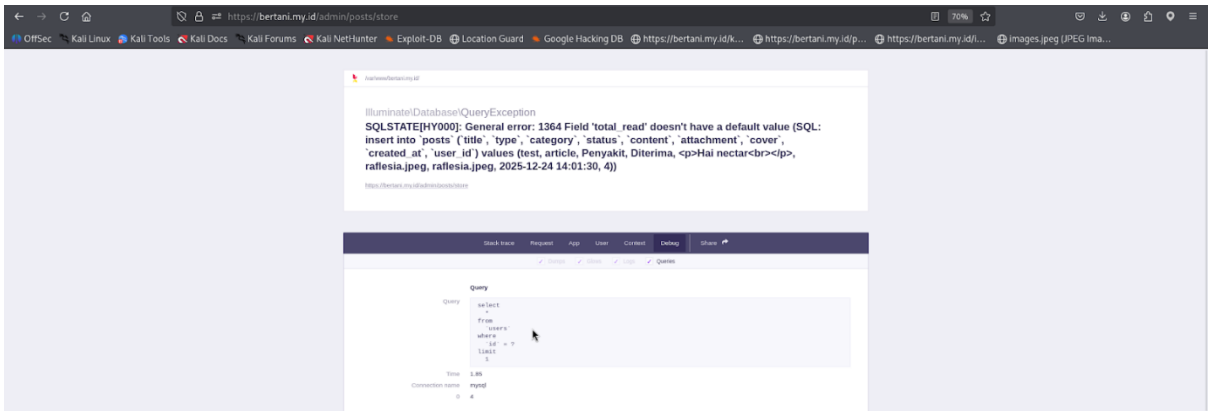
STEPS TO REPRODUCE

1. Login ke Akun Anda sebagai admin di URL https://bertani.my.id/login

2. Masuk ke url https://bertani.my.id/admin/posts/create



3. Lalu saat posts disimpan akan menampilkan informasi kolom category dan database menggunakan mysql



EXPECTED RESULT

Server produksi seharusnya dikonfigurasi untuk menyembunyikan detail error teknis dari pengguna. Pesan error harus bersifat umum (misalnya: "500 Server Error").

ACTUAL RESULT

Aplikasi menampilkan pesan error spesifik SQLSTATE[HY000] beserta jalur direktori server (*server file paths*) dan versi framework/database.

IMPACT

Information Disclosure (Low): Pengungkapan informasi teknis dan struktur query dasar yang dapat membantu penyerang dalam tahap pengumpulan informasi (*reconnaissance*), meskipun tidak secara langsung memberikan akses ke data sensitif pengguna.

RECOMMENDATION

1. Nonaktifkan Mode Debug: Pastikan file .env di server produksi memiliki pengaturan APP_DEBUG=false.
2. Gunakan Halaman Error Generik: Pastikan Laravel dikonfigurasi untuk menampilkan halaman umum (seperti halaman 500) kepada pengguna luar.

REFERENCES

1. **OWASP Top 10 - A05:2021 Security Misconfiguration**: https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
2. **Laravel Documentation - Error Handling**: https://laravel.com/docs/10.x/errors